

**FILE PATH TRAVERSAL: VALIDATION OF FILE EXTENSION
WITH NULL BYTE BYPASS**

Nivel: Practitioner

Tipo de explotación: Path Traversal mediante bypass de validación de extensión utilizando byte nulo (Null byte bypass)

Materia: CNO IV WAP

Alumno: Gasca López Santiago Isaac – 184730

Docente: Mtro. Servando López Contreras



1. Marco Teórico

En el desarrollo de aplicaciones web seguras, es común implementar validaciones de extensiones de archivos para restringir la carga de recursos a formatos permitidos (como imágenes). No obstante, si el backend utiliza lenguajes o librerías de bajo nivel que interactúan con APIs de sistemas de archivos vulnerables al tratamiento de caracteres nulos (bytes nulos, %00), la lógica de validación puede romperse. El byte nulo actúa como un carácter de fin de cadena para el sistema operativo, ignorando todo lo que se escriba después de este, mientras que el filtro de la aplicación web sigue evaluando la extensión final.

2. Objetivo

Demostrar y documentar la explotación exitosa de una vulnerabilidad de Path Traversal protegida por una validación estricta de extensión de archivo, empleando técnicas de inyección de byte nulo a través de Burp Suite para extraer información confidencial del sistema operativo.

3. Vulnerabilidad

Nombre de la vulnerabilidad: File Path Traversal (Validation of file extension with null byte bypass).

Descripción: La aplicación valida que el parámetro del archivo concluya con una extensión esperada (ej. .png). Al no sanitizar correctamente los caracteres especiales de control como el byte nulo, permite que un atacante trunque la ruta de validación y acceda a archivos protegidos del sistema..

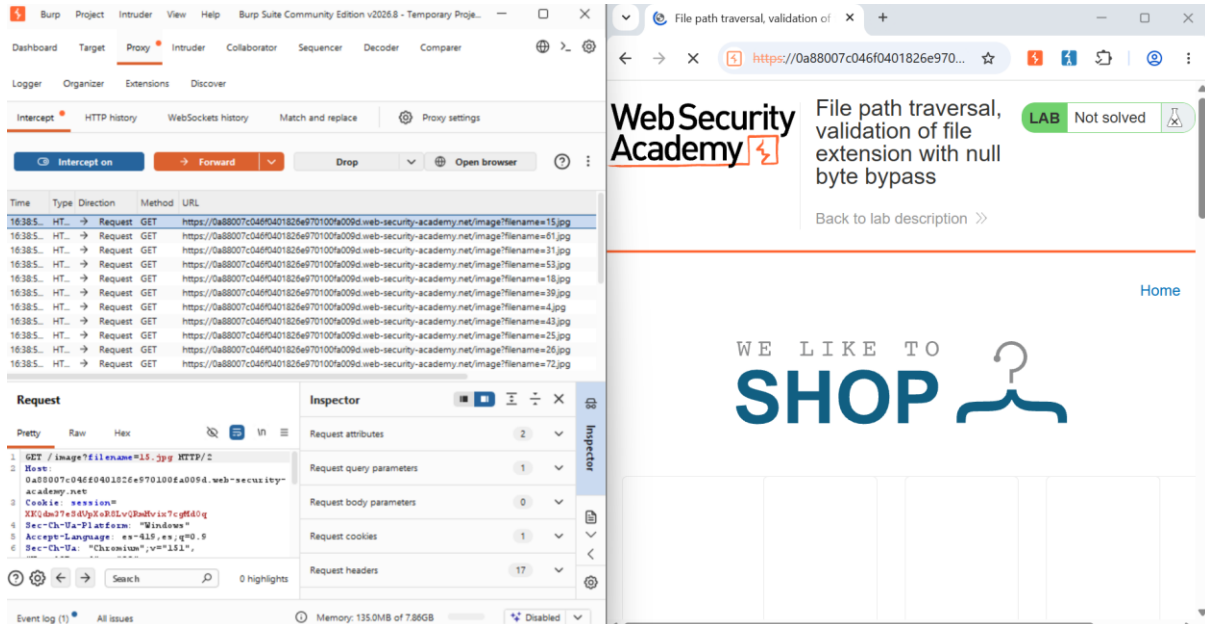
4. Procedimiento paso a paso

4.1 Configuración del entorno de intercepción:

Se configuró el proxy de Burp Suite asegurando la captura correcta del tráfico HTTP proveniente del navegador en el laboratorio de PortSwigger.

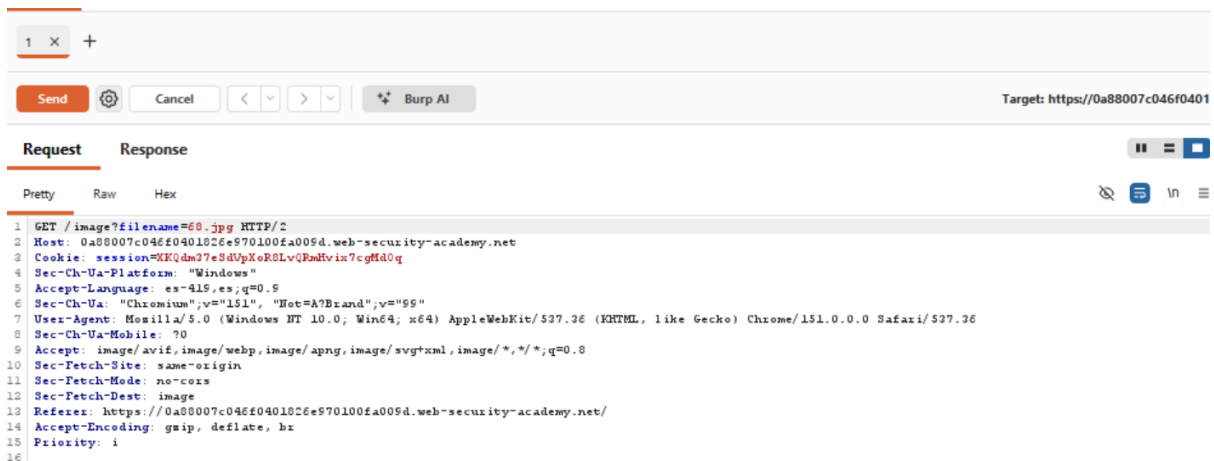
4.2 Generación de la petición base:

Se interactuó con la plataforma web para solicitar un recurso gráfico, generando la solicitud HTTP estándar del tipo GET /image?filename=68.jpg



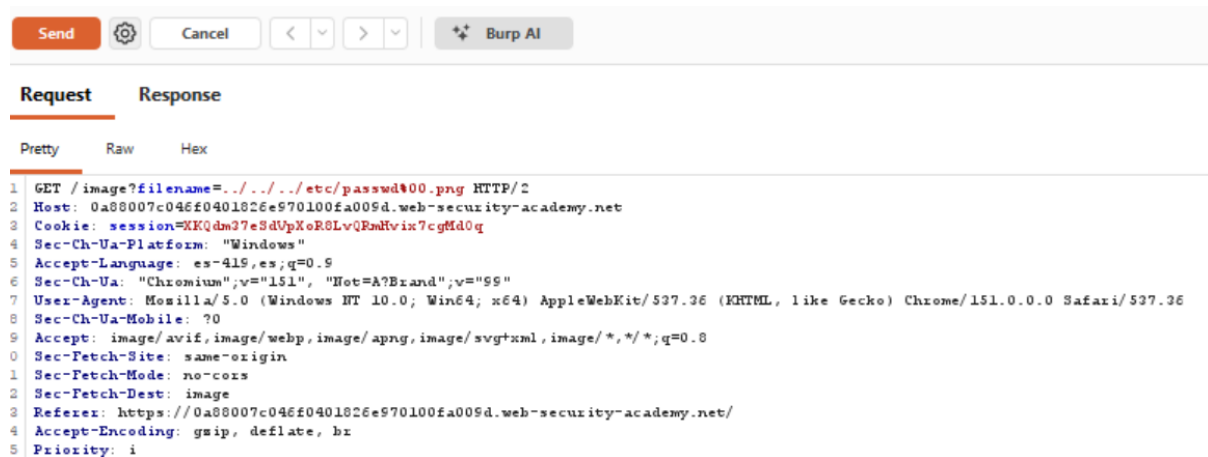
4.3 Captura y envío a Repeater:

La solicitud capturada se redirigió al módulo Repeater para facilitar la manipulación y el reenvío controlado de los parámetros de entrada.



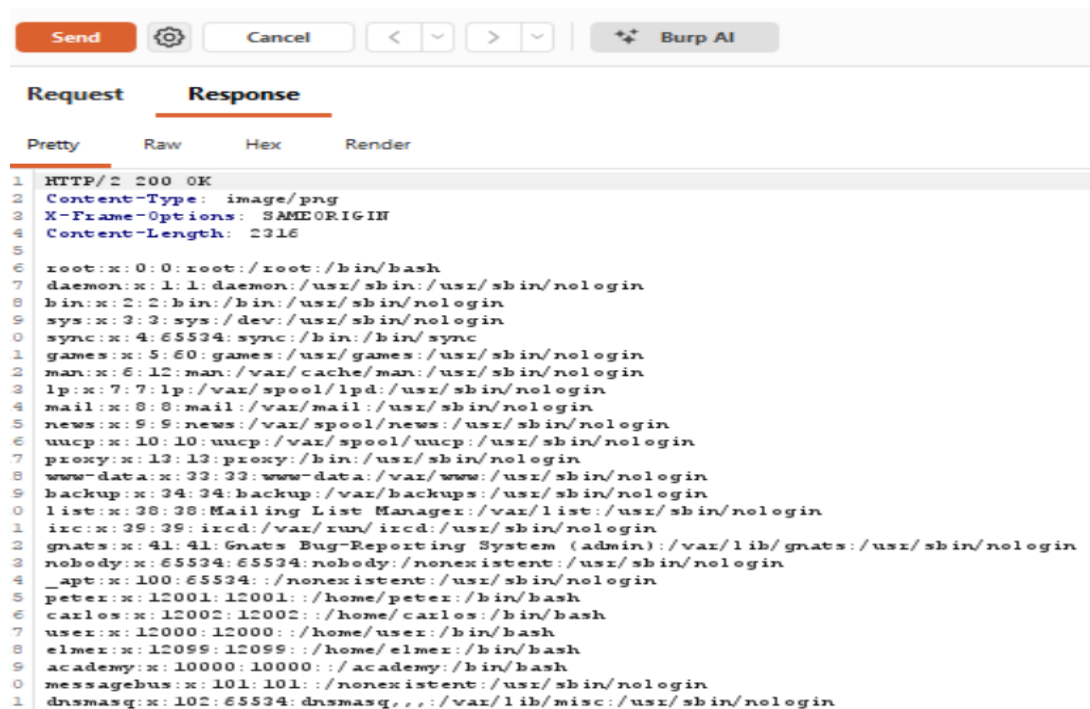
4.4 Inyección del payload con byte nulo:

Se modificó el parámetro filename integrando las secuencias de escape de directorios, el archivo objetivo, el byte nulo codificado y la extensión requerida para cumplir con la validación superficial: GET /image?filename=../../etc/passwd%00.png HTTP/2



4.5 Validación del resultado y cierre del laboratorio:

Se ejecutó la petición, confirmando que el filtro validó positivamente la extensión final, mientras que el backend procesó el byte nulo y devolvió con éxito el contenido del archivo /etc/passwd en la respuesta HTTP.



4.5 Interfaz web de PortSwigger con la notificación en verde de "Lab Solved", validando la conclusión exitosa del ejercicio:



5. Payload utilizado

El Payload inyectado en la petición HTTP fue:

- GET /image?filename=../../../../etc/passwd%00.png HTTP/2

6. Explicación Técnica del Payload

6.1 ¿Cómo opera el filtro del servidor?

El sistema de validación comprueba de manera superficial que la cadena de texto termine exactamente con la extensión autorizada (png).

6.2 ¿Por qué funciona el bypass?

Al incluir un byte nulo (%00), el filtro de la aplicación web lee la cadena completa y asume que es válida porque finaliza en .png. Sin embargo, al pasar el parámetro a las funciones internas del sistema operativo, el byte nulo corta la lectura de la cadena en ese punto exacto, provocando que el sistema ignore la extensión y lea únicamente la ruta de directorios anterior (../../../../etc/passwd).

7. Mitigación

- 7.1 Actualización de entornos y librerías: Utilizar lenguajes de programación modernos y frameworks actualizados que manejen de forma segura las cadenas de texto y rechacen caracteres de control nulos.
- 7.2 Uso de listas blancas estrictas y canonicalización: Validar los nombres de archivos mediante expresiones regulares seguras o catálogos predefinidos, evitando procesar caracteres especiales o secuencias de escape en las rutas.

8. Conclusión

La práctica evidenció que las validaciones de extensiones vulnerables al uso de bytes nulos son ineficaces frente a ataques de Path Traversal. La adopción de controles estrictos de entrada y el uso de funciones seguras de gestión de archivos son fundamentales para prevenir brechas de seguridad.

9. Fuente

PortSwigger Web Security Academy. File path traversal, validation of file extension with null byte bypass. Recuperado de PortSwigger Labs.